Nearly nine years after the warning, Israeli government domains still lack effective protection against email spoofing

13 October 2026

TL;DR

In December 2017, Israel's National Cyber Security Authority (the predecessor of today's Israel National Cyber Directorate) published guidance on SPF, DKIM and DMARC to reduce email impersonation [3]. Our DNS audit on 13 October 2026 found that **nine of the 18 government domains examined use `p=none`**, a DMARC policy that does not ask receiving mail servers to reject or quarantine messages that fail authentication. These include domains used by the ministries of Finance, Foreign Affairs, Education and Health, as well as the Tax Authority. We also found no DMARC record of its own for `mossad.gov.il`, and no SPF record at the root of that domain. Receiving servers may use the policy published for `gov.il` instead, but that policy does not request rejection either.

Findings

An attacker does not need much technical knowledge to put a government address, such as `anyone@any-domain.gov.il`, in the sender field of an email. The message can be sent without access to a government mailbox or mail server. A receiving mail service can check whether the sender is authorized to use the claimed domain, and DMARC allows the domain owner to specify what should happen when that check fails. In nine of the domains we examined, the published policy is `p=none`, meaning the domain owner does not ask receiving servers to reject or quarantine messages that fail DMARC authentication.

Domain	DMARC policy
`gov.il`	`p=none; sp=none`
`mof.gov.il` — Ministry of Finance	`p=none; sp=none`
`mfa.gov.il` — Ministry of Foreign Affairs	`p=none; sp=none`
`health.gov.il` — Ministry of Health	`p=none; sp=none`
`education.gov.il` — Ministry of Education	`p=none`
`taxes.gov.il` — Tax Authority	`p=none; sp=none`
`moin.gov.il` — Ministry of Interior	`p=none; sp=none`
`moh.gov.il` — Ministry of Health	`p=none`
`energy.gov.il` — Ministry of Energy	`p=none; sp=none`

For three other domains — `mossad.gov.il`, `govextra.gov.il` and `data.gov.il` — we found no DMARC record published by the domain itself. There was also no SPF record at the root of `mossad.gov.il`. Some receiving mail servers may look for a policy at the parent domain, `gov.il`, but the policy there is `p=none; sp=none` and likewise does not request rejection of messages that fail authentication. In the records we examined, none of these domains has a published policy asking receiving servers to reject such messages.

The Ministry of Justice (`justice.gov.il`) and Ministry of Agriculture (`moag.gov.il`) both publish `p=reject` for their main domains, but their `sp=none` setting leaves covered subdomains without the same rejection policy. The Israel Police (`police.gov.il`), Prime Minister's Office (`pmo.gov.il`), Ministry of Transport (`mot.gov.il`) and Geological Survey (`gsi.gov.il`) publish rejection policies for their subdomains as well. We also found that `gov.il`, `mof.gov.il` and `energy.gov.il` use the same DMARC record, `dmarc.dmarc.gov.il`, which is configured with `p=none; sp=none`.

What do SPF, DKIM and DMARC do?

SPF (Sender Policy Framework)

SPF allows an organization to publish a list of mail servers authorized to send emails on its behalf. When an email arrives, the receiving server can check whether it came from an authorized server.

However, SPF does not necessarily verify the sender address visible to the recipient, so SPF alone cannot prevent email impersonation.

DKIM (DomainKeys Identified Mail)

DKIM allows an organization to digitally sign outgoing emails. The receiving server can verify that the email was authorized by the signing domain and that its signed contents were not altered in transit.

However, DKIM does not necessarily verify that the signing domain matches the sender address visible to the recipient, so DKIM alone cannot prevent email impersonation.

DMARC (Domain-based Message Authentication, Reporting and Conformance)

DMARC builds on SPF and DKIM to verify that an email is authorized to use the sender address visible to the recipient. It allows an organization to instruct receiving mail servers what to do when verification fails: accept the message normally (`none`), send it to spam (`quarantine`), or reject it (`reject`).

Without an enforcing DMARC policy, even emails that fail authentication may still reach the recipient.

The risks

On 27 July 2026, the Israel Tax Authority warned about fraudulent emails sent in its name, claiming that recipients were under investigation for tax offences. The messages included links intended to steal personal information and account credentials [1]. The Israel National Cyber Directorate also issued alerts in December 2025 and February 2026 about emails impersonating the Israel Police [2]. Someone who believes a message came from a government authority may follow a link or give away information they would never share with an unknown sender.

Seeing an official government address in the sender field can make a fraudulent message more convincing, even though that address alone proves nothing about who sent it. When a domain publishes `p=none`, it is not asking receiving mail servers to reject messages that fail DMARC authentication, leaving the outcome to the providers' own filters and other security measures.

What needs to happen now

Changing a DNS record from `p=none` to `p=reject` takes only a few minutes. Doing it without disrupting legitimate government email takes more work. Alongside their normal mail servers, ministries use older applications, automated notification systems and external suppliers that send email on their behalf. Some of these systems may send messages with the correct visible address but still fail the authentication checks DMARC relies on. Switching directly to rejection could therefore block legitimate notifications and correspondence, including messages that citizens depend on.

Each organization needs to identify the systems that legitimately send mail, working with the teams that operate its applications and with external suppliers. It then needs to correct SPF and DKIM configurations so that authentication matches the visible sender domain, and use DMARC reports to find what is still failing. Once legitimate mail passes the checks, the policy can move from monitoring to quarantine and finally rejection, while checking that essential messages continue to be delivered. For organizations operating under ISO/IEC 27001, this is also a risk to be assessed and treated as part of their security management, even though the standard does not specifically require DMARC [4].

The right change depends on how each domain is used. A domain that never sends email can publish records stating that no server is authorized to send on its behalf, together with a rejection policy, without affecting legitimate outgoing mail. The Ministry of Justice and Ministry of Agriculture need to address their subdomain policies, while changes to the shared `dmarc.dmarc.gov.il` record require coordination across the domains using it, so that fixing one does not disrupt another.

Maintaining government email systems is complicated, particularly when old software and external suppliers are involved, but that is no justification for leaving citizens exposed to phishing attacks that established safeguards can reduce. The government has had guidance on these mechanisms since 2017. Nearly nine years is more than enough time to identify the systems that need fixing and put proper protection in place.

Sources

[1] Israel Tax Authority, Fraud warning issued on 27 July 2026 (Hebrew).

[2] Israel National Cyber Directorate, Alert 1950B concerning impersonation of the Israel Police, 23 December 2025; updated alert, 9 February 2026 (Hebrew).

[3] National Cyber Security Authority, Guidance on SPF, DKIM and DMARC, December 2017 (Hebrew).

[4] International Organization for Standardization, ISO/IEC 27001:2022 — Information security management.